

SQL Injection Attack — Listing Database Contents on Oracle

Platform: PortSwigger Web Security Academy

Lab: SQL injection attack, listing the database contents on Oracle

Vulnerability: SQL Injection

Database: Oracle

Technique: UNION-Based SQL Injection

Testing Type: Authorized Security Testing

1. Overview

A SQL Injection vulnerability was successfully exploited in the PortSwigger Web Security Academy lab.

The vulnerability allowed manipulation of a backend SQL query through a user-controlled parameter. A UNION-based SQL Injection technique was used to enumerate the Oracle database and retrieve its contents.

2. Methodology

The assessment followed these steps:

1. Identified the vulnerable input parameter.
 2. Determined the number of columns returned by the original query.
 3. Identified columns capable of displaying text.
 4. Used Oracle-specific database metadata to enumerate available tables.
 5. Identified the relevant application table and its columns.
 6. Retrieved the required database contents.
 7. Verified successful exploitation within the lab.
-

3. Technical Analysis

The vulnerability occurred because user input was incorporated into an SQL query without proper parameterization.

Using UNION-based SQL Injection, the original query could be extended to return information from the Oracle database.

Oracle-specific metadata views were used during enumeration because database structure and metadata syntax vary between database management systems.

Attack flow:

Injection Point → Column Enumeration → Metadata Enumeration → Table Discovery → Data Retrieval

4. Impact

Successful exploitation could allow an attacker to:

- Enumerate database tables and structure.
- Access sensitive application data.
- Retrieve authentication-related information.
- Potentially compromise user accounts.
- Modify or delete data if excessive database privileges are available.

Severity: High

5. Root Cause

The root cause was improper handling of user-controlled input within the SQL query.

The application failed to separate SQL commands from user-supplied data, allowing the query structure to be manipulated.

6. OWASP & CWE

OWASP Top 10: A03:2021 — Injection

CWE-89: Improper Neutralization of Special Elements used in an SQL Command (SQL Injection)

7. Remediation

- Use prepared statements and parameterized queries.
 - Never concatenate untrusted input directly into SQL queries.
 - Implement server-side input validation.
 - Apply least-privilege permissions to database accounts.
 - Prevent detailed database errors from being exposed.
 - Perform regular security testing.
-

8. Conclusion

The Oracle database enumeration lab was successfully completed. The exercise demonstrated how SQL Injection can be used to move from query manipulation to database structure discovery and data retrieval.

The primary defense is the use of **parameterized queries**, supported by proper input validation and least-privilege database permissions.

Evidence: Lab successfully completed; screenshots were not included.